

Security, Privacy & AI Governance Framework

Purpose

The AI-Assisted Loan Origination System (AI-LOS) processes sensitive customer, financial, collateral, and credit information. This document defines the security, privacy, and AI governance controls incorporated throughout the loan origination lifecycle to ensure confidentiality, integrity, availability, regulatory compliance, and responsible AI usage.

The framework follows the principle of **Security by Design** and **Responsible AI by Design**, ensuring that security and governance controls are embedded throughout the system rather than added as an afterthought.

Objectives

The objectives of this framework are to:

- Protect sensitive customer and financial information.
 - Ensure only authorized users can access the system.
 - Maintain data integrity throughout the loan lifecycle.
 - Support responsible and explainable AI decisions.
 - Detect AI-related risks such as hallucinations and bias.
 - Provide complete auditability of all activities.
 - Enable regulatory compliance and operational transparency.
-

Security Principles

The AI-Assisted Loan Origination System is designed based on the following security principles:

- Confidentiality
- Integrity
- Availability
- Authentication
- Authorization
- Accountability
- Traceability
- Non-Repudiation
- Privacy by Design

- Security by Design

Security Controls Across the Loan Origination Lifecycle

Module	Security Controls
Customer Onboarding	Multi-Factor Authentication (MFA), Identity Verification, Session Validation
Document Upload	Malware Scan, File Type Validation, File Integrity Check
Financial Analysis	Data Validation, Encryption, Access Control
Collateral Assessment	Role-Based Access, Secure Document Storage
Legal Due Diligence	Legal Document Integrity Validation
Credit Risk Assessment	AI Governance, Human Review, Audit Logging
Loan Documentation Package	Encryption, Version Control, Secure Transmission

Identity & Access Management

The system implements Role-Based Access Control (RBAC) to ensure users can access only the functions required for their responsibilities.

Roles include:

- Relationship Manager
- Credit Officer
- Legal Officer
- Collateral Officer
- Sanctioning Authority
- Branch Manager
- System Administrator
- Auditor

Authentication controls include:

- Multi-Factor Authentication (MFA)
 - Secure Password Policy
 - Session Timeout
 - Role-Based Authorization
 - Least Privilege Access
 - Segregation of Duties
-

Data Protection Controls

Sensitive customer information shall be protected throughout the loan lifecycle.

Controls include:

- Encryption of data at rest.
 - Encryption of data in transit.
 - Secure API communication.
 - Data masking for Personally Identifiable Information (PII).
 - Secure document storage.
 - Backup and disaster recovery.
 - Data retention according to regulatory requirements.
-

AI Governance Controls

The AI Governance Engine validates every AI-generated recommendation before it can be considered by business users.

The governance engine performs:

- AI Confidence Score Evaluation
- Explainability Validation
- Bias Detection
- Hallucination Detection
- Data Quality Validation
- Policy Compliance Verification
- Human-in-the-Loop Validation
- AI Model Version Tracking
- Recommendation Traceability

AI recommendations are advisory only and shall never replace human judgment.

AI Security Controls

To ensure secure and trustworthy AI usage, the system incorporates the following controls:

- Prompt Injection Detection
 - Sensitive Data Leakage Prevention
 - Unauthorized AI Access Detection
 - AI Model Version Validation
 - AI Output Validation
 - Secure API Authentication
 - AI Request Logging
 - AI Response Monitoring
-

Vulnerability Management

Security vulnerabilities shall be proactively identified and remediated throughout the system lifecycle.

The organization shall perform:

- Vulnerability Assessment
- Secure Configuration Review
- Patch Management
- Dependency Security Review
- API Security Testing
- Penetration Testing
- Continuous Security Monitoring

Critical vulnerabilities shall be remediated before production deployment.

Audit & Monitoring

Every critical activity performed within the system shall be recorded to ensure accountability and regulatory compliance.

The audit trail includes:

- User ID
- User Role
- Login Timestamp

- Session ID
- Loan Application ID
- Activity Performed
- AI Model Version
- AI Confidence Score
- Governance Validation Result
- Human Review Decision
- Approval History
- Timestamp
- System Generated Logs

Audit logs shall be immutable and retained according to organizational policies.

Human Oversight

The AI-Assisted Loan Origination System follows the Human-in-the-Loop principle.

The system automatically routes applications for manual review whenever:

- AI Confidence Score is below the configured threshold.
- Bias is detected.
- Hallucination is detected.
- Explainability is unavailable.
- Mandatory financial information is missing.
- Policy exceptions are identified.
- Risk exceeds the organization's approved threshold.
- Loan amount exceeds delegated approval authority.

The Credit Officer and Sanctioning Authority retain full responsibility for the final lending decision.

Regulatory Alignment

The solution has been conceptually designed considering industry best practices and banking governance principles, including:

- Basel III Risk Management Principles
- RBI Digital Banking and Information Security Guidelines
- Risk Governance Frameworks
- Data Privacy Principles

- Internal Banking Control Frameworks

(Note: This prototype is for demonstration purposes and is not a certified implementation of any regulatory standard.)

Future Enhancements

Future versions of the platform may include:

- Blockchain-based Audit Trail
- Smart Contract Integration
- Real-Time Threat Intelligence
- AI Model Drift Monitoring
- Zero Trust Security Architecture
- Continuous Compliance Monitoring
- Automated Vulnerability Scanning
- AI Security Risk Dashboard



US-S001 Role-Based Access Control (RBAC)

User Story

As the AI-Assisted Loan Origination System,

I want to enforce Role-Based Access Control (RBAC),

So that users can access only the functions and information authorized for their role.

Acceptance Criteria

Scenario 1 – Authorized Access

Given a user has a valid role,

When the user accesses the system,

Then only the permitted modules and actions shall be available.

Scenario 2 – Unauthorized Access

Given a user attempts to access a restricted function,

When authorization is evaluated,

Then access shall be denied and the attempt shall be recorded in the audit log.

US-S002 AI Governance Validation

User Story

As the AI Governance Engine,

I want to validate AI-generated recommendations before presenting them to business users,

So that only reliable, explainable, and policy-compliant recommendations are used in the lending process.

Acceptance Criteria

The system shall validate:

- Confidence Score
- Explainability
- Bias Detection
- Hallucination Detection
- Data Quality
- Model Version

If any validation fails, the application shall be routed for mandatory human review.

US-S003 Security Audit Logging

User Story

As the AI-Assisted Loan Origination System,
I want to record all security-relevant events,
So that system activities are fully traceable for audit, monitoring, and regulatory purposes.

Acceptance Criteria

The audit log shall capture:

- User ID
- Role
- Timestamp
- Activity
- Loan Application ID
- AI Model Version
- Governance Result
- Approval Decision

Audit records shall be immutable and retained according to organizational policy.

Control Checklist for Risk & Compliance Review

This gives the impression that every AI recommendation can be independently verified by Risk, Compliance, Audit, or Internal Control teams.

Control Checklist for Risk & Compliance Review

The following checklist shall be reviewed before any AI-assisted recommendation is considered for credit decision-making.

Control Area	Validation	Status
Customer Identity Verified	KYC completed and validated	✓
User Authentication	Authorized user accessed the system	✓
Role-Based Access Control	Appropriate user role verified	✓

Financial Data Completeness	All mandatory financial documents available	✓	
Data Quality Validation	Missing or inconsistent data identified	✓	
AI Confidence Score	Above configured threshold	✓	
Explainability Available	AI recommendation is explainable	✓	
Bias Assessment	No material bias detected	✓	
Hallucination Detection	AI output validated	✓	
Human Review Required	Triggered if governance thresholds breached	✓	
Credit Policy Compliance	Lending policy validation completed	✓	
Approval Authority Validation	Delegation of authority verified	✓	
Audit Trail Generated	All actions recorded	✓	
Security Validation	No security exceptions detected	✓	
Final Recommendation	Ready for Credit Officer Review	✓	

Risk & Compliance Officer Responsibilities

The Risk & Compliance Officer shall verify that:

- All mandatory governance controls have been completed.
- AI recommendations comply with the organization's lending policies.
- Data quality issues have been resolved before decision-making.
- Human review has been performed where governance thresholds were breached.
- All approvals are granted by authorized personnel.
- Audit logs are complete, accurate, and tamper-evident.
- Security and privacy controls have been applied throughout the process.
- Any policy exceptions are documented, justified, and approved.

Governance Decision Matrix

Governance Result	Action
All controls passed	Proceed to Credit Officer Review
Data quality issues identified	Resolve data issues before processing
Low AI confidence	Mandatory Human Review
Bias detected	Escalate for Risk Review
Hallucination detected	Reject AI recommendation and perform manual assessment
Missing explainability	Manual review required
Security control failure	Block processing until resolved
Policy exception identified	Escalate to Risk & Compliance Officer

Governance Principle: AI recommendations within the Loan Origination System are advisory in nature. Final lending decisions remain the responsibility of authorized business users. The system ensures transparency, explainability, auditability, and human oversight throughout the decision-making process.